

Product Requirements Document (PRD)

Detailed product definition, scope, business rules, acceptance criteria and release plan

Product: Closecraft AI Revenue Operating System | Release: MVP / Validation Build | Status: Production engineering baseline | Date: 6 October 2026

Core principle: AI handles speed, repetition and scale. Humans handle judgement, negotiation and high-value sales decisions.

1. Executive Summary

Closecraft is an AI-assisted lead-to-revenue operating system designed for businesses that already generate inbound demand but lose revenue through slow response, inconsistent qualification, weak follow-up, fragmented conversations and poor human handoff. The MVP focuses on a WhatsApp-first lead-to-qualified-opportunity loop rather than attempting to replace a full enterprise CRM.

Primary outcome: Turn more of the leads a business already has into qualified sales opportunities and appointments, while preserving human control over high-value or uncertain decisions.

2. Product Strategy

2.1 Positioning

Primary message: Turn More Leads Into Sales.

Supporting message: AI qualifies, follows up and routes opportunities. Your sales team closes.

Category: AI Revenue Operating System / Lead-to-Revenue Operating System.

2.2 Initial ICP

- Businesses with roughly 50 or more inbound leads per month.
- Businesses where a lead has enough economic value to justify active sales follow-up.
- Teams already using WhatsApp for prospect communication.
- Founder-led sales teams, agencies, professional services, education/training, real estate, consultants and B2B services are initial test segments.
- At least one human sales owner must exist for escalation and closing.

2.3 Anti-ICP

- Businesses with negligible lead volume or transaction value.
- Pure self-service ecommerce where human qualification is unnecessary.
- Teams unwilling to connect lead sources or measure outcomes.
- Use cases requiring autonomous regulated advice, unapproved financial commitments or unsupported sensitive decision-making.

3. Problem Statement

The target customer does not necessarily have a lead-generation problem. It has a lead-conversion operations problem. Leads arrive across channels, response quality varies by staff member, follow-up is forgotten, qualification is subjective, managers lack visibility and high-intent prospects can disappear before a salesperson acts.

4. Goals and Non-Goals

Goals	Non-Goals
-------	-----------

Reduce response time; improve qualification completion; create more qualified opportunities; increase appointments; make human intervention explicit; prove customer ROI.	Replace Salesforce/HubSpot; build a closer marketplace; ship voice AI; support every channel; build enterprise forecasting; autonomously negotiate discounts without authority.
---	---

5. Personas and Jobs-to-be-Done

Persona	Jobs-to-be-Done	Success Signal
Owner/Admin	Configure the revenue engine, integrations, qualification and governance; see whether Closecraft pays for itself.	Clear ROI, low operational risk, renews subscription.
Sales Manager	Know which leads matter, who owns them and where AI needs review.	Fewer missed leads, faster team action, visible accountability.
Closer/Sales Rep	Understand a lead quickly and take the next best action.	Less admin, more qualified conversations and appointments.
Setter/SDR	Qualify, follow up and schedule efficiently.	Higher qualification and booking throughput.
Lead/Prospect	Get fast, relevant responses without repetitive or misleading automation.	Useful conversation, easy opt-out and simple booking.

6. Scope and Priorities

Capability	Priority	MVP Definition
Multi-tenancy & RBAC	P0	Isolated workspaces, users, memberships and roles.
Lead capture	P0	WhatsApp, API/webhook, manual create/import, source attribution and deduplication.
Lead workspace	P0	Profile, timeline, conversation, qualification, owner, next action and outcome.
AI qualification	P0	Workspace-specific questions, factors, score, confidence, evidence and recommendation.
Human review	P0	Approve, edit, reject, assign or handle manually based on policy.
Follow-up	P0	Configurable sequence, quiet hours, retries, stop conditions and opt-out.
Appointments	P0	Calendar availability, booking, confirmation and status.
Dashboard	P0	Attention queue and validation KPIs.
Audit & governance	P0	Material AI, human, configuration and security events.

Knowledge base	P1	Approved business facts used to ground AI replies.
Billing/usage	P1	Plan, usage, payment status and pilot limits.
Advanced automation canvas	P2	Post-validation.
Advanced revenue intelligence	P2	Post-validation.

7. Detailed Functional Requirements

7.1 Authentication and Workspace

- Email/password or supported identity provider authentication.
- Create workspace during onboarding.
- Owner can invite users and assign supported roles.
- Server-side tenant isolation is mandatory for every tenant-owned record.

7.2 Dashboard

- Lead with 'Needs Your Attention' rather than vanity charts.
- Show new leads, qualified leads, appointments, overdue follow-ups, review items and outcome value where available.
- Each card must deep-link to the actionable record.
- Filters: date range, owner, source and status where applicable.

7.3 Leads

- Search, filter, sort and saved views.
- Canonical statuses: New, Engaged, Qualifying, Qualified, Appointment, Opportunity, Won, Lost.
- Lead detail combines profile, timeline/conversation and AI intelligence.
- Allow manual owner assignment, stage update, notes and outcome recording.

7.4 AI Qualification

- Admin configures ideal customer criteria, questions, disqualifiers, factor weights and thresholds.
- AI extracts explicit facts and inferred signals separately.
- Unknown information remains unknown.
- Assessment contains score, confidence, factor breakdown, evidence references and recommended next action.
- Low-confidence or restricted actions route to human review.

7.5 Human-in-the-Loop

- Dedicated AI Actions queue with urgency and confidence filters.
- Policy triggers include high deal value, low confidence, pricing/discounts, negotiation, complaints, sensitive topics and custom rules.
- Reviewer can approve, edit, reject, assign or take over.
- Every review decision is logged.

7.6 Follow-up

- Sequences use configurable delays and maximum attempts.
- Before every send, re-check reply state, opt-out, human takeover, appointment, won/lost and quiet hours.
- Replies cancel or recalculate pending steps.
- Do not continue persuasion after explicit opt-out.

7.7 Appointments

- Connect at least one calendar provider.
- Offer only provider-confirmed availability.
- Do not mark booked until provider confirms.
- Support confirmed, rescheduled, cancelled, completed and no-show states.

7.8 Knowledge

- Admins add approved product/service, pricing, FAQ, objection and company information.
- Only active workspace knowledge may ground that workspace AI.
- Changes are versioned or timestamped for traceability.

7.9 Analytics

- North star: qualified opportunities generated.
- Track first-response time, contact rate, qualification completion, appointment rate, human override rate, conversion and revenue per lead when outcome data exists.
- Pilot export must support before/after analysis.

8. Business Rules

ID	Rule
BR-01	AI may only execute actions explicitly permitted by workspace policy.
BR-02	Permissions, consent, billing and tenant isolation are deterministic controls, never AI decisions.
BR-03	Opt-out immediately blocks future automated outbound messages on that channel.
BR-04	Human takeover pauses incompatible automation.
BR-05	A provider failure cannot be presented as a successful message or appointment.
BR-06	Low-confidence qualification cannot be represented as certainty.
BR-07	Cross-tenant data access, retrieval or model context is prohibited.
BR-08	All material AI recommendations and human overrides must be auditable.

9. UX and Design Requirements

- Desktop-first operational shell with responsive mobile workflows for hot leads, review, reply, assignment and appointments.
- Design language: premium, intelligent, commercial and trustworthy. Avoid sci-fi AI aesthetics and decorative complexity.
- Core palette: dark navy #0C1424, surface #111C30, warm off-white #F5F1E8, muted #AEB9CC, electric blue #4F7CFF.
- Use skeletons for loading and meaningful processing states for AI.
- Meet WCAG 2.2 AA for core flows, including keyboard navigation, focus visibility, labels and non-colour status cues.

10. Success Metrics and Validation

Metric	Definition	MVP Target Type
Qualified opportunities	Leads meeting configured threshold and accepted by workflow.	Primary north-star; improve versus baseline.
Median first response	Lead receipt to first valid response.	Material reduction versus baseline.
Qualification completion	Completed qualification / engaged leads.	Increase.
Appointment rate	Booked appointments / eligible leads.	Increase.
Human override rate	Edited/rejected reviewed AI actions / reviewed actions.	Monitor quality, not minimise blindly.
Pilot-to-paid renewal	Paid pilots that continue.	Key willingness-to-pay signal.
Customer ROI	Incremental attributable value / Closecraft cost.	Positive and explainable.

11. Release Acceptance Criteria

- Inbound lead is captured in the correct workspace with source attribution.
- Lead can receive a compliant response, complete qualification and receive a structured assessment.
- High-risk or low-confidence action can be intercepted by human review.
- Human can take over, reply, assign and book/record an appointment.
- Follow-up respects stop conditions and opt-out.
- Material actions are auditable.
- Tenant isolation and RBAC pass security tests.
- Pilot metrics are reportable/exportable end-to-end.

12. Delivery Phases

Phase	Deliverable	Exit Criterion
1	Foundation: auth, workspace, RBAC, DB, audit, CI/CD.	Tenant isolation and deployment verified.

2	Lead core: capture, dedupe, list/detail, timeline.	Inbound lead reliable.
3	Messaging: WhatsApp, conversation UI, delivery states, opt-out.	Two-way messaging verified.
4	AI qualification: profiles, structured outputs, confidence, evaluation.	Representative evaluation baseline passes.
5	Human control: review queue and approvals.	Restricted actions cannot bypass policy.
6	Follow-up scheduler and stop conditions.	No duplicate/unsafe sends in E2E tests.
7	Calendar and appointment state.	Provider-confirmed booking works.
8	Dashboard, outcomes and export.	Pilot metrics measurable.
9	Hardening: security, accessibility, load, recovery and observability.	Production readiness gate passes.

13. Risks and Mitigations

Risk	Mitigation
AI becomes a commodity CRM feature	Compete on measurable lead-to-revenue workflow, WhatsApp-first operations, human control and customer-specific process data.
Hallucinated or unsafe responses	Grounded knowledge, structured outputs, deterministic guardrails, review thresholds and evaluation suite.
Messaging/provider dependency	Adapter layer, health monitoring, retries and graceful manual fallback.
Weak willingness to pay	Paid pilots, ROI baseline, renewal test and narrow ICP before expansion.
Overbuilding	Strict P0/P1/P2 release boundary and validation gate.
Tenant/privacy incident	Server-side isolation, least privilege, encryption, audit and security testing.

User Flow Specification

End-to-end user journeys, system decisions, exception paths and screen transitions

Product: Closecraft AI Revenue Operating System | Release: MVP / Validation Build | Status: Production engineering baseline | Date: 6 October 2026

Core principle: AI handles speed, repetition and scale. Humans handle judgement, negotiation and high-value sales decisions.

1. Flow Conventions

- Actor types: Prospect, Owner/Admin, Sales Manager, Sales Rep/Closer, Setter and System/AI.
- Every flow must preserve workspace isolation, permissions, consent state and auditability.
- AI recommendations are probabilistic; permissions and policy enforcement are deterministic.
- A flow is complete only when success, failure, retry and human fallback paths are defined.

2. Information Architecture

Area	Primary Screens
Access	Login, Signup, Forgot Password, Workspace Creation
Onboarding	Business, Ideal Customer, Qualification, AI/Human Rules, Connections, Test, Launch
Operations	Dashboard, Leads, Lead Detail, Inbox, AI Actions, Pipeline, Appointments
Configuration	Knowledge, AI Settings, Integrations, Team, Billing, Settings, Audit Logs
Analytics	Revenue Intelligence, AI Performance, Source Performance

3. Flow A - Signup and Workspace Onboarding

Step	Actor	Action / Screen	System Response	Next
A1	Owner	Signup: name, work email, password, company.	Validate; create identity.	A2
A2	System	Email verification/auth success.	Create pending workspace.	A3
A3	Owner	Business setup: website, industry, offer, average deal value, timezone.	Persist profile.	A4
A4	Owner	Ideal customer and disqualifiers.	Create ICP configuration.	A5
A5	Owner	Qualification questions, weights and thresholds.	Validate rule consistency.	A6
A6	Owner	Human approval rules.	Apply safe defaults plus custom triggers.	A7
A7	Owner	Connect WhatsApp and calendar.	Validate credentials and scopes.	A8
A8	Owner	Run test lead.	Execute sandbox flow without live outreach.	A9
A9	Owner	Launch workspace.	Enable inbound processing; audit event.	Dashboard

4. Flow B - Inbound Lead to Qualification

Step	Decision / Action	System Behaviour
B1	Inbound lead received.	Verify source/integration, resolve workspace, validate payload and idempotency.
B2	Existing identity?	Normalise phone/email. Link or update according to deterministic dedupe rules.
B3	Consent/opt-out allows contact?	If no, store lead but do not automate outbound messaging.
B4	Automation allowed?	If yes, create/send first response. If no, create human task.
B5	Prospect replies.	Persist message, update timeline and cancel/recalculate incompatible scheduled follow-ups.
B6	Qualification incomplete?	Ask next permitted question using active qualification profile.
B7	Enough evidence?	Generate structured factor assessment, score and confidence.
B8	Policy decision.	Auto-continue only when action is allowed and confidence/risk thresholds pass.
B9	Qualified/high intent.	Assign or route to human; offer appointment when permitted.
B10	Not ready.	Continue configured follow-up or nurture until stop condition.

Flow invariant: A prospect message, explicit opt-out, human takeover, confirmed appointment, Won or Lost state must re-evaluate and cancel incompatible scheduled automation.

5. Flow C - AI Qualification and Recommendation

Stage	Input	Processing	Output
Context	Lead profile, recent conversation, active rules, approved knowledge.	Assemble bounded tenant-scoped context.	Versioned context references.
Extraction	Prospect statements.	Extract explicit facts and signals.	Structured fields; unknown remains unknown.
Scoring	Factors and configured weights.	Apply deterministic scoring where possible.	Factor scores and total score.
Confidence	Evidence quantity/quality and model certainty.	Estimate confidence; detect ambiguity.	Confidence value/category.

Recommendation	Score, intent, policy and conversation state.	Select only from allowed next actions.	Ask, follow up, assign, review, book or disqualify suggestion.
Guardrail	Recommendation plus policy.	Block restricted actions and require review when needed.	Auto action or AI Action review item.

6. Flow D - Human Review

Step	Reviewer Experience	System Behaviour
D1	Open AI Actions queue.	Show urgency, lead, proposed action, confidence and reason.
D2	Open review item.	Show conversation evidence, qualification, value and policy trigger.
D3	Choose Approve.	Execute action if still valid; audit reviewer and result.
D4	Choose Edit.	Save edited content/action, execute as human-approved and audit delta.
D5	Choose Reject.	Do not execute; require optional reason; update AI Action state.
D6	Choose Assign/Manual.	Assign owner and pause incompatible automation.
D7	Stale item detected.	Revalidate lead state before execution; prevent obsolete action.

7. Flow E - Follow-Up

- Sequence is created only for eligible lead and active policy.
- Scheduler creates durable due jobs.
- At execution time, re-check opt-out, reply, appointment, owner activity, human takeover, lead outcome, quiet hours and max attempts.
- If eligible, generate or select permitted message, send via provider and record delivery state.
- On transient provider error, retry with bounded backoff. On repeated failure, surface operational review.
- On prospect reply, cancel or recalculate remaining steps.

8. Flow F - Appointment Booking

Step	Action	Failure Path
F1	Lead becomes eligible for appointment.	If calendar unavailable, create human task rather than fabricate slots.
F2	Fetch provider availability in workspace/lead timezone.	Provider timeout: retry or request manual scheduling.
F3	Offer valid slots.	Expired slot: refresh availability.

F4	Prospect selects slot.	Revalidate before booking.
F5	Create provider event.	Do not mark confirmed until provider success.
F6	Send confirmation and notify owner.	Message failure does not invalidate confirmed booking; surface send retry.
F7	Reschedule/cancel webhook.	Update appointment and lead timeline idempotently.

9. Flow G - Sales Rep Daily Workflow

- Open Dashboard and scan Needs Your Attention.
- Resolve hot lead, overdue follow-up and AI review items in priority order.
- Open Lead Detail to inspect summary, conversation, score, evidence and next action.
- Reply directly, approve/edit AI draft, assign owner or take over.
- Book appointment or update stage/outcome.
- Return to queue; resolved item is removed or reprioritised.

10. Flow H - Admin Configuration

- Open Settings -> AI / Qualification / Human Approval.
- Edit configuration in draft state.
- Validate thresholds, conflicts and required fields.
- Preview effect using test lead where possible.
- Publish new version.
- New decisions use new version; historical assessments retain previous version reference.
- Audit actor, timestamp and changed configuration.

11. Exception and Recovery Matrix

Condition	User Experience	System Requirement
AI unavailable	Show manual review / retry state.	Preserve lead and conversation; retry safely.
WhatsApp disconnected	Banner and integration alert.	Stop sends, retain queued work, mark health degraded.
Duplicate webhook	No visible duplicate.	Idempotently acknowledge without duplicate domain action.
Duplicate lead	Show linked/merged identity where relevant.	Never silently overwrite conflicting data.
Low confidence	"AI needs help" review state.	Ask clarification or route human based on policy.
Opt-out	Confirm no further automated contact.	Cancel channel outbound jobs immediately.

Calendar error	Booking not confirmed.	Preserve selected context and retry/manual fallback.
Unauthorized action	Access denied.	Do not leak inaccessible record existence/data.
Stale AI recommendation	Explain recommendation is outdated.	Recompute/revalidate before execution.

12. Screen-to-Screen Navigation

From	Primary Action	To
Login	Authenticate	Dashboard or Onboarding
Dashboard	Open attention item	Lead Detail / AI Action / Appointment
Leads	Select lead	Lead Detail
Lead Detail	Review AI recommendation	AI Action drawer/modal
Lead Detail	Book appointment	Appointment flow
AI Actions	Open item	Review detail
Review detail	Approve/Edit/Assign	Lead Detail / Queue
Settings	Edit qualification	Qualification configuration
Integrations	Connect provider	OAuth/provider connection state
Analytics	Open segment	Filtered Leads view

13. Mobile Priority Flows

- Dashboard attention queue with tap-to-action cards.
- Lead detail summary, recent messages and primary reply/assign/book actions.
- AI Actions approval with evidence, confidence and Approve/Edit/Reject controls.
- Appointments today view and status changes.
- Notifications deep-link into the relevant record.

14. Flow Acceptance Criteria

- Every P0 journey has success, failure and retry behaviour.
- No user can cross workspace boundaries through URL manipulation or API calls.
- No autonomous action can bypass human-review policy.
- Opt-out is effective immediately.
- Provider-dependent success is shown only after provider confirmation.
- All material transitions produce timeline/audit events.

Software Requirements Specification (SRS)

Technical architecture, functional requirements, data model, security, AI controls, APIs, quality and operations

Product: Closecraft AI Revenue Operating System | Release: MVP / Validation Build | Status: Production engineering baseline | Date: 6 October 2026

Core principle: AI handles speed, repetition and scale. Humans handle judgement, negotiation and high-value sales decisions.

1. Purpose and Scope

This SRS defines the implementable software requirements for the Closecraft MVP. It is technology-agnostic where practical and prescriptive where correctness, security or operability requires a contract. The system is a multi-tenant SaaS with a responsive web client, APIs, asynchronous jobs, messaging/calendar integrations and AI-assisted qualification.

2. System Context and Architecture

Logical architecture: Web Client -> API/Application Layer -> Authentication/RBAC -> Domain Services -> Relational Database + Durable Queue/Scheduler -> Provider Adapters -> AI Orchestration -> Analytics/Observability.

- Frontend: responsive web application, desktop-first for operations and mobile-capable for review/reply.
- Backend: stateless application services with versioned APIs and server-side authorisation.
- Database: relational system of record with workspace/tenant ownership on all tenant data.
- Queue: durable asynchronous processing for webhooks, messaging, AI, follow-up, calendar callbacks and retries.
- Integrations: provider-specific adapters isolate external schemas from domain logic.
- AI layer: structured-output orchestration, prompt/config versioning, provider abstraction, evaluation and usage telemetry.

3. Domain Model

Entity	Key Fields / Relationships
Workspace	id, name, timezone, status, plan, configuration, timestamps
User	id, auth identity, name, email, status
Membership	workspace_id, user_id, role, permission overrides
Lead	workspace_id, identity, source, owner, stage, score, consent, timestamps
Conversation	workspace_id, lead_id, channel, automation_state
Message	conversation_id, direction, sender_type, provider_id, content/ref, delivery state, timestamps
QualificationProfile	workspace_id, criteria, questions, weights, thresholds, version, active
Assessment	lead_id, profile_version, factors, score, confidence, evidence refs, recommendation
AIAction	lead_id, type, proposed payload, confidence, policy trigger, reviewer, state
FollowUp	lead_id, conversation_id, due_at, attempt, policy_version, state
Appointment	lead_id, owner, provider/calendar refs, start/end, timezone,

	state
KnowledgeItem	workspace_id, type, content/ref, state, version
Integration	workspace_id, provider, credential_ref, scopes, health, state
AuditEvent	workspace_id, actor, action, object, result, timestamp, metadata
Outcome	lead_id, won/lost, value, currency, reason, timestamp

4. Functional Requirements

ID	Area	Requirement	Pri.
FR-001	Workspace	The system shall create isolated customer workspaces and bind all tenant-owned records to exactly one workspace.	P0
FR-002	Auth	The system shall authenticate users and maintain secure sessions.	P0
FR-003	RBAC	The system shall enforce role/permission checks server-side for every protected operation.	P0
FR-004	Users	Owners/Admins shall invite, deactivate and assign roles to workspace users.	P0
FR-005	Lead Capture	The system shall ingest leads via WhatsApp, webhook/API and manual/import paths.	P0
FR-006	Idempotency	Inbound webhooks shall be idempotent and duplicate delivery shall not duplicate domain actions.	P0
FR-007	Dedupe	The system shall normalise lead identifiers and apply deterministic duplicate handling.	P0
FR-008	Timeline	The system shall maintain a chronological lead timeline of messages, AI assessments, assignments, reviews, appointments and outcomes.	P0
FR-009	Messaging	The system shall send/receive WhatsApp messages through an approved provider and persist provider delivery states.	P0
FR-010	Consent	The system shall check channel opt-out/consent state	P0

		before scheduling or sending automated outbound messages.	
FR-011	Qualification Config	Admins shall configure questions, criteria, disqualifiers, factor weights and thresholds without code changes.	P0
FR-012	Assessment	The system shall produce structured qualification assessments with factors, unknowns, score, confidence, evidence references and recommended action.	P0
FR-013	Human Review	The system shall create review items when configured risk, confidence, value, topic or action thresholds are met.	P0
FR-014	Review Actions	Authorised reviewers shall approve, edit, reject, assign or handle proposed AI actions manually.	P0
FR-015	Follow-up	The system shall schedule follow-up with configurable delays, attempts, quiet hours and stop conditions.	P0
FR-016	Stop Conditions	Replies, opt-outs, conversion, loss, appointment or human takeover shall cancel/recalculate incompatible pending automation.	P0
FR-017	Assignment	The system shall support lead ownership and maintain assignment history.	P0
FR-018	Calendar	The system shall connect at least one calendar provider and retrieve availability.	P0
FR-019	Booking	The system shall create appointments and only mark them confirmed after provider confirmation.	P0
FR-020	Dashboard	The dashboard shall show operational KPIs and a prioritised attention queue.	P0
FR-021	Search	Users shall search permitted leads and conversations and filter by owner, source, stage and status.	P0
FR-022	Knowledge	Admins shall maintain approved tenant-scoped knowledge used for grounded AI responses.	P1

FR-023	Integrations	The system shall expose provider connection status, health and recoverable errors.	P0
FR-024	Audit	The system shall record material human, AI, configuration, integration and security events.	P0
FR-025	Outcomes	Users shall record Won/Lost and optional value/currency/reason.	P0
FR-026	Analytics	The system shall calculate core validation metrics and export pilot data.	P0
FR-027	Billing	The system shall represent plan, usage and payment state sufficient for paid pilots.	P1
FR-028	Notifications	The system shall notify authorised users of review-required, hot lead, appointment and integration failure events.	P1

5. AI and Model Requirements

ID	Requirement
AI-001	All AI outputs used by application logic shall conform to validated structured schemas.
AI-002	Invalid model output shall fail closed, retry safely or route to human review.
AI-003	Prompts, model identifiers and qualification configuration shall be versioned and traceable per assessment.
AI-004	The model shall distinguish explicit prospect evidence from inference; absent data shall remain unknown.
AI-005	AI-generated outbound content shall be bounded by approved workspace knowledge and communication policy.
AI-006	Discounts, commitments, sensitive actions and other restricted operations shall be blocked by deterministic policy unless explicitly authorised.
AI-007	Low confidence shall trigger clarification or human review according to policy.
AI-008	The platform shall record provider/model, latency, usage/cost and result status for each material AI job.
AI-009	AI provider abstraction shall allow model substitution without changing core domain contracts.
AI-010	Tenant-scoped retrieval shall prevent cross-workspace knowledge access.

AI-011	Prompt injection in prospect messages or documents shall not override system policy, permissions or tool constraints.
AI-012	Private chain-of-thought shall not be stored or exposed; store concise decision rationale and evidence references instead.

6. Security and Privacy Requirements

ID	Requirement
SEC-001	Encrypt traffic using current TLS and protect sensitive stored data with platform-appropriate encryption.
SEC-002	Store provider/API secrets in a secrets manager or encrypted credential store; never expose them to the browser or normal logs.
SEC-003	Enforce tenant isolation server-side and test horizontal/vertical privilege escalation.
SEC-004	Apply least-privilege RBAC to Owner, Admin, Sales Manager, Closer, Setter and Viewer.
SEC-005	Use secure session management, CSRF protection where applicable and appropriate authentication rate limits.
SEC-006	Validate webhook signatures where supported and implement replay/idempotency protection.
SEC-007	Validate and sanitise inputs and encode outputs to mitigate injection/XSS risks.
SEC-008	Maintain tamper-resistant audit records for material administrative and approval actions.
SEC-009	Support data export/deletion and configurable retention aligned with applicable obligations.
SEC-010	Minimise PII sent to AI providers and document subprocessor/data handling configuration.
SEC-011	Redact credentials, tokens and sensitive payloads from logs and error reports.
SEC-012	Run dependency, secret, static analysis and vulnerability scanning before production release.

7. Non-Functional Requirements

ID	Category	Requirement / Target
NFR-001	Availability	Pilot target $\geq 99.5\%$ monthly application availability, excluding announced maintenance and upstream provider outages.
NFR-002	Latency	Interactive non-AI API p95 target ≤ 500 ms under expected pilot load.

NFR-003	AI UX	AI operations over 2 seconds run asynchronously and expose meaningful processing state.
NFR-004	Webhook	Acknowledge valid inbound webhooks quickly and perform durable work asynchronously.
NFR-005	Scalability	Stateless services and queue workers shall scale horizontally; no global tenant state.
NFR-006	Reliability	Transient external failures use bounded exponential backoff and dead-letter handling.
NFR-007	Accessibility	Core user journeys target WCAG 2.2 AA.
NFR-008	Responsive	Dashboard, lead detail, AI review, reply and appointments function on modern mobile widths.
NFR-009	Observability	Monitor queue depth, webhook/message failures, AI errors, latency, integration health and auth anomalies.
NFR-010	Backup	Automated database backups and documented restore test before production pilot.
NFR-011	Integrity	Use transactions/idempotency where duplicate execution could create messages, bookings or outcomes.
NFR-012	Cost	Per-workspace AI/messaging usage telemetry, caps and alerts protect gross margin.

8. RBAC Baseline

Capability	Owner/Admin	Manager	Closer/Setter	Viewer
Workspace settings	Full	Limited	No	No
Users/roles	Full	View/limited	No	No
Leads/conversations	Full	Full	Assigned/permitted	Read permitted
AI approvals	Full	Full	Assigned/permitted	No
Qualification policy	Full	View	View	View
Integrations/billing	Full	Health/read	No	No
Analytics	Full	Full	Own/team	Read permitted
Audit logs	Full	Operational read	Own actions	No

9. State Machines

- Lead: New -> Engaged -> Qualifying -> Qualified -> Appointment -> Opportunity -> Won/Lost.
- AI Action: Proposed -> Auto-approved or Needs Review -> Approved/Edited/Rejected/Expired -> Executed/Failed.
- Follow-up: Scheduled -> Due -> Sent -> Replied/Rescheduled/Cancelled/Exhausted/Failed.
- Appointment: Proposed -> Pending Provider -> Confirmed -> Completed/Rescheduled/Cancelled/No-show.
- Integration: Disconnected -> Connecting -> Connected -> Degraded -> Error -> Disconnected.

10. API and Integration Contract Principles

- Version public/internal APIs and validate request/response schemas.
- Use provider signature verification and idempotency for inbound callbacks.
- Use idempotency keys for retryable create operations such as outbound messages and appointments.
- Translate provider payloads inside adapters; domain services must not depend on raw provider schemas.
- Persist provider correlation IDs for traceability.
- Do not report provider-dependent success until provider acknowledgement is received.
- Return stable domain error codes that distinguish validation, authorisation, conflict, provider failure and retryable failure.

11. Core API Surface (Logical)

Method / Resource	Purpose
POST /v1/leads	Create lead manually/API.
GET /v1/leads	List/search/filter permitted leads.
GET/PATCH /v1/leads/{id}	Read/update permitted lead.
GET /v1/leads/{id}/timeline	Read lead activity timeline.
POST /v1/conversations/{id}/messages	Send authorised message.
POST /v1/webhooks/{provider}	Receive provider events idempotently.
POST /v1/leads/{id}/assessments	Request/recompute qualification assessment.
GET/PATCH /v1/ai-actions/{id}	Read/review proposed AI action.
POST /v1/leads/{id}/assign	Assign owner.
GET /v1/calendars/availability	Retrieve provider availability.
POST /v1/appointments	Create provider-backed appointment.
GET/PATCH /v1/settings/qualification	Read/update qualification configuration.
GET /v1/analytics/summary	Retrieve workspace KPI summary.

12. Analytics Event Contract

Event	Minimum Properties
lead.created	workspace_id, lead_id, source, timestamp
message.received / sent	lead_id, conversation_id, channel, sender_type, delivery_state
qualification.completed	lead_id, profile_version, score, confidence, factor_summary
ai_action.proposed / reviewed / executed	lead_id, action_type, confidence, reviewer/outcome
followup.scheduled / sent / cancelled	lead_id, policy_version, attempt, reason
appointment.booked / changed	lead_id, owner_id, status, time, provider
lead.assigned	lead_id, previous_owner, new_owner
outcome.recorded	lead_id, outcome, value, currency, reason
integration.health_changed	provider, previous_state, current_state

13. Error Handling and Resilience

- User-facing errors explain what failed, what remains safe and the next action.
- Transient background failures retry automatically with bounded backoff.
- Repeated failures enter dead-letter/review state with operational visibility.
- Duplicate callbacks do not create duplicate domain state.
- AI failure degrades to manual handling.
- Provider outages do not corrupt local lead/conversation state.
- Stale AI actions are revalidated before execution.

14. Testing and Quality Gates

Layer	Minimum Gate
Unit	Domain rules, scoring/routing, stop conditions, permissions and state transitions.
Integration	Messaging, calendar, auth, database, queue and AI structured-output validation.
Contract	Webhook schemas, provider fixtures and API schema compatibility.
E2E	Onboarding, inbound lead, qualification, review, follow-up, assignment, booking, opt-out and outcome.
Security	RBAC/IDOR, tenant isolation, secrets, spoof/replay, injection and dependency scanning.
AI Evaluation	Representative qualification set, escalation cases, unsupported claims and hallucination checks.
Load	Webhook bursts, queue processing and dashboard reads at forecast plus safety margin.

Recovery	Provider outage, queue retry, failed AI call, calendar failure and database restore exercise.
----------	---

15. Deployment and Operations

- Separate development, staging and production environments.
- Infrastructure and database migrations are version-controlled and repeatable.
- CI gates include tests, lint/static analysis, secret/dependency checks and build verification.
- Production changes use controlled deployment with rollback capability.
- Operational dashboards cover API health, queue depth, provider failures, AI errors/cost, database health and authentication anomalies.
- Define incident ownership, escalation path, backup restoration procedure and provider outage runbooks.

16. Definition of Done

- Acceptance criteria satisfied and tests pass.
- Tenant scoping and server-side authorisation verified.
- Loading, empty, success and error states implemented.
- Audit and telemetry added for material operations.
- Accessibility checks pass for affected core flow.
- No known P0/P1 security defect remains open.
- Operational/support documentation is sufficient for another engineer to deploy and diagnose the feature.

17. Production Readiness Gate

Area	Required Before Paid Pilot
Infrastructure	Production environment, managed DB, backups, secret management, HTTPS and monitoring.
Messaging	Approved business messaging integration, callbacks and policy-compliant templates where required.
AI	Production credentials, retry/fallback policy, cost limits, evaluation baseline and prompt versions.
Security	RBAC/tenant tests, rate limits, audit log, privacy/retention process and incident contact.
Operations	Support path, integration-health visibility, dead-letter/retry procedure and runbooks.
Commercial	Plan/usage rules, terms/privacy notices and billing/invoicing process.
Analytics	Baseline and post-launch metrics available per pilot workspace.